

Actividad 11

File path traversal, validation of start of path

Bypass de filtro — validación parcial

Nombre: Tristán Rivera Magdalena Yesenia

Matrícula: 174702

Materia / Grupo: CNO IV — Programación WAP · T37A

Profesor: Servando López Contreras

Herramienta: Burp Suite Community Edition

URL: <https://portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path>

OBJETIVO

Evadir una validación que solo revisa que la ruta empiece con el directorio permitido, sin revisar el resto del string.

EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

Este endpoint recibe la ruta completa del archivo (no solo el nombre). El servidor valida que el parámetro comience con `/var/www/images/`, pero no revisa qué viene después de eso. Al cumplir el inicio requerido, se puede anexas `../` justo después para salirse del directorio de todos modos.

PROCEDIMIENTO PASO A PASO

1. Activar Intercept on en Burp y hacer clic en un producto.
2. Interceptar la request — aquí `filename` ya trae la ruta completa (ej. `/var/www/images/40.jpg`).
3. Mandarla a Repeater.
4. Conservar el prefijo `/var/www/images/` y añadir `../../../../etc/passwd` justo después.
5. Enviar y confirmar la fuga en el Response y el badge "Lab solved".

PAYLOAD UTILIZADO

```
GET /image?filename=/var/www/images../../../../etc/passwd HTTP/2
```

La validación "empieza con `/var/www/images/`" se cumple literalmente; el resto del string (`../../../../etc/passwd`) nunca es inspeccionado y termina resolviendo fuera del directorio permitido.

MITIGACIÓN RECOMENDADA

No basta con validar el prefijo de un string. Hay que resolver la ruta canónica completa (eliminando `../`, symlinks, etc.) y validar esa ruta final contra el directorio permitido.

